

Частное образовательное учреждение дополнительного
профессионального образования
«ВЫШТЕХ» (ОАНО ДПО «ВЫШТЕХ»)

Факультет информационной безопасности

Отчёт по домашней работе № 3

по дисциплине «Менеджмент и аудит информационной
безопасности»

Тема: «Комплексный анализ ИБ-угроз,
количественная оценка рисков и разработка
программы Security Awareness»

Выполнил:

Студент группы F-402-1

Наседкин Павел Николаевич

Проверил:

ex-инструктор академии Cisco,

кандидат педагогических наук, доцент

Шабалин Андрей Михайлович

Дата сдачи: «06» сентября 2026 г.

Оценка: _____

Оглавление

1. Задание домашней работы (полный текст)	3
2. Цели и задачи работы	7
3. Ход выполнения	8
3.1. Этап 1. Идентификация риска (Качественный подход) . . .	8
3.2. Этап 2. Анализ и оценивание риска (Качественный подход)	8
3.3. Этап 3. Количественная оценка риска (Финансовый расчет)	9
3.4. Этап 4. Программа повышения осведомленности (Security Awareness)	11
4. Заключение	13
5. Список использованных источников	14
ПРИЛОЖЕНИЕ А. РАСЧЕТНЫЕ ТАБЛИЦЫ И МАТРИЦЫ	15

1. Задание домашней работы (полный текст)

Все необходимое программное обеспечение доступно по ссылке: <https://disk.360.yandex.ru/d/0ha1dFNajk9tPg>

Задание

Цель работы: Научиться выявлять ИБ-угрозы, оценивать их качественными и количественными методами, экономически обосновывать затраты на защиту и разрабатывать целевые программы обучения сотрудников для нейтрализации рисков.

Каждому слушателю необходимо выбрать реальный ИТ-актив организации, выявить для него угрозу и выполнить её комплексный анализ, пройдя 4 обязательных этапа.

Этап 1. Идентификация риска (Качественный подход)

1. Выбор актива: Выберите любой рабочий ИТ-компонент бизнеса (например: корпоративный сайт, CRM-систему, почтовый сервер, облачную базу документов бухгалтерии).
2. Анализ угроз: Изучите новости ИБ, ИТ-форумы или аналитические отчеты и найдите техническую проблему, актуальную для этого актива.
3. Связь с БДУ ФСТЭК: Зайдите в официальный государственный каталог БДУ ФСТЭК России и подберите точный код угрозы (УБИ.XXX), описывающий вашу проблему.
4. Итог этапа: Сформулируйте финальный риск в одно предложение: «Существует риск [взлома/отказа/утечки] актива [Название] злоумышленниками через [Уязвимость/ код УБИ]».

Этап 2. Анализ и Оценивание риска (Качественный подход)

1. Природа риска: Распишите технический сценарий – как именно хакер реализует угрозу и к какому бизнес-сбою в компании это приведет.
2. Определение уровня: По матрице рисков («светофору») присвойте риску степени (Низкий/ Средний/ Высокий):
 - Вероятность (Р): Насколько легко провести атаку?

- Последствия (I): Насколько сильно пострадает бизнес (финансы, репутация в СМИ, простой процессов)?
3. Оценивание: Сформулируйте внутренний критерий компании (например: «Простой продаж дольше 2 часов – неприемлем») и сделайте вывод: допустим ли этот риск для руководства или его нужно срочно снижать?

Этап 3. Количественная оценка риска (Финансовый расчет)

Переведите ваш пример в плоскость денег. Рассчитайте показатели на основе формул риск-менеджмента, сделав логичные экономические допущения:

1. AV (Asset Value): Сколько стоит сам актив или его восстановление с нуля?
2. EF (Exposure Factor): Коэффициент ущерба при атаке (какой % от общей стоимости актива будет уничтожен/ заблокирован)?
3. SLE (Single Loss Expectancy): Финансовый убыток от одного инцидента.
4. ARO (Annualized Rate of Occurrence): Сколько раз в год (по статистике) эта атака может успешно произойти?
5. ALE (Annualized Loss Expectancy): Ожидаемый годовой убыток компании, если ничего не предпринимать.
6. CBA (Cost-Benefit Analysis): Обоснуйте внедрение защитного решения (контрмеры) через экономическую выгоду: $CBA = ALE - ALE' - CV$, где CV – годовая стоимость контрмеры, а ALE' – новый уменьшенный годовой убыток после внедрения защиты.

Этап 4. Программа повышения осведомленности (Security Awareness)

Так как большинство технических уязвимостей активируются из-за ошибок людей (слабые пароли, клики по ссылкам), разработайте целевую программу обучения сотрудников именно под ваш кейс:

1. Целевая аудитория: Каких конкретно сотрудников нужно обучить (всех, только бухгалтеров, только ИТ-администраторов, контент-менеджеров)?

2. Формат обучения: Как вы будете доносить информацию (вебинар, памятка в чат, тренировочная фишинговая атака)?
3. Правила ИБ: Сформулируйте 3 – 4 четких и понятных правила (что сотрудникам делать нужно, а что категорически нельзя), чтобы закрыть человеческий фактор этой уязвимости.

Пример выполнения:

- **Этап 1:** Объект – сайт компании. Проблема – устаревшие плагины. БДУ ФСТЭК: УБИ.003 (Угроза использования уязвимостей ПО). Риск: «Существует риск взлома сайта через известную уязвимость (УБИ.003) в устаревшем плагине обратной связи».
- **Этап 2:** Природа – хакеры через эксплойт заливают вредоносный код, Яндекс блокирует сайт красной табличкой, клиенты уходят. Вероятность – Высокая (сканируют постоянно). Последствия – Средние (финансовые потери от простоя). Итог – риск Высокий. Бизнес-критерий: «Блокировка сайта поисковиками неприемлема». Вывод: риск недопустим.
- **Этап 3:**
 - AV (разработка сайта) = 500 000 руб.
 - EF (ущерб от взлома/простоя) = 60% (0,6).
 - SLE (разовый убыток) = $500\,000 \times 0,6 = 300\,000$ руб.
 - ARO (частота атак в год) = 2 раза.
 - ALE (годовой убыток без защиты) = $300\,000 \times 2 = 600\,000$ руб./год.
 - Контрмера: Покупка WAF (защитного экрана) за CV = 50 000 руб./год. Она снижает риски до минимума (ALE' = 10 000 руб.).
 - CBA = $600\,000 - 10\,000 - 50\,000 = 540\,000$ руб. экономической выгоды. Защита оправдана.
- **Этап 4 (Осведомленность):** Ломают админки сайтов часто из-за кражи паролей людей. Аудитория: контент-менеджеры сайта. Формат: памятка + имитация фишинга «от хостинга». Правила: 1) Запрещен один

пароль для личной почты и админки сайта. 2) Включить двухфакторную аутентификацию (2FA) для входа на сайт. 3) При письмах о блокировках от хостинга – не кликать по ссылкам, а заходить на хостинг через собственные закладки браузера.

2. Цели и задачи работы

Целью домашней работы №3 является формирование практических навыков выявления, качественного и количественного анализа рисков информационной безопасности, а также разработка экономически обоснованных мер защиты и программ повышения осведомленности персонала в соответствии с требованиями ГОСТ Р ИСО/МЭК 27005.

Задачи работы:

1. Выбрать критичный ИТ-актив организации и идентифицировать актуальную угрозу с привязкой к Банку данных угроз (БДУ) ФСТЭК России.
2. Провести качественный анализ риска: описать вектор атаки, оценить вероятность и последствия по матрице рисков.
3. Выполнить количественную (финансовую) оценку риска, рассчитав показатели AV, EF, SLE, ARO, ALE.
4. Обосновать внедрение контрмеры методом анализа затрат и выгод (CBA).
5. Разработать целевую программу Security Awareness для минимизации влияния человеческого фактора.

3. Ход выполнения

3.1. Этап 1. Идентификация риска (Качественный подход)

1. **Выбор актива:** Сервер 1С:Предприятие и облачная база документов бухгалтерии. Данный актив обеспечивает не только ведение бухгалтерского и налогового учёта, но и обслуживание отдела продаж (оформление сделок, выставление счетов, складской учёт), что делает его критичным для непрерывности ключевых бизнес-процессов компании.
2. **Анализ угроз:** Основным вектором проникновения шифровальщиков (ransomware) является фишинговая рассылка с вредоносными вложениями на адреса сотрудников финансовых отделов и отдела продаж.
3. **Связь с БДУ ФСТЭК:** В каталоге БДУ ФСТЭК России данной проблеме соответствует код **УБИ.170** (Угроза неправомерного шифрования информации).
4. **Итог этапа (строго по шаблону):**
«Существует риск отказа актива Сервер 1С:Предприятие злоумышленниками через неправомерное шифрование информации (УБИ.170).»

3.2. Этап 2. Анализ и оценивание риска (Качественный подход)

1. **Природа риска (Технический сценарий):**
Злоумышленник получает доступ к сети через фишинговое письмо с вредоносным макросом. Вредоносное ПО сканирует сетевые папки, обнаруживает критичные файлы баз данных 1С (с расширениями *.1cd*, *.mdf*, *.ldf*) и файлы конфигураций (*.cf*, *.cfe*), после чего применяет криптографический алгоритм с ключом, известным только атакующему. Легальные пользователи теряют доступ к информации, возникает полный отказ в обслуживании бизнес-процессов (бухгалтерия, отдел продаж, склад), а злоумышленник требует выкуп за расшифровку. Даже при наличии ключа структура базы данных часто оказывается необратимо нарушенной.

2. Определение уровня (Матрица рисков):

- **Вероятность (Р) – Высокая.** Фишинговые атаки автоматизированы и массовы.
- **Последствия (I) – Высокие.** Полная остановка бизнес-процессов (бухгалтерия, продажи, склад), прямые финансовые потери, репутационные риски.
- **Итоговый уровень риска: Высокий.**

3. Оценивание (Внутренний критерий):

- *Критерий компании:* «Простой бухгалтерии и отдела продаж больше 2 часов является неприемлемым».
- *Вывод:* Риск **недопустим**. Требуется срочное внедрение технических и организационных мер по его снижению.

3.3. Этап 3. Количественная оценка риска (Финансовый расчет)

Переводим риск в финансовую плоскость на основе формул риск-менеджмента.

1. **AV (Asset Value):** Стоимость сервера, лицензий 1С и оценка ущерба от восстановления. Принимаем $AV = 3\,000\,000$ руб.
2. **EF (Exposure Factor):** При успешной атаке без изолированных резервных копий будет заблокировано до 80% данных. $EF = 0,8$ (80%).
3. **SLE (Single Loss Expectancy):** Финансовый убыток от одного инцидента.

$$SLE = AV \times EF = 3\,000\,000 \times 0,8 = 2\,400\,000 \text{ руб.}$$

4. **ARO (Annualized Rate of Occurrence):** На основе экспертной оценки, опирающейся на аналитику Positive Technologies серии CODE RED (тенденции 2024–2025 гг. по ransomware-атакам на российские организации), частота одной успешной атаки шифровальщика в год для организации среднего размера принимается как $ARO = 1$.

5. **ALE (Annualized Loss Expectancy):** Ожидаемый годовой убыток без защиты.

$$ALE = SLE \times ARO = 2\,400\,000 \times 1 = 2\,400\,000 \text{ руб./год.}$$

Обоснование контрмеры (CBA — Cost-Benefit Analysis):

Внедряем комплексную защиту:

- **EDR-система:** Kaspersky Endpoint Security для бизнеса 11 (KES 11) с модулем поведенческого анализа.
- **Система резервного копирования:** Veeam Backup & Replication 12 с изоляцией бэкапов по правилу 3-2-1 (три копии данных, на двух разных типах носителей, одна — офлайн, с функцией Immutable Backup).
- **CV (Cost of Countermeasure):** Годовая стоимость лицензий и поддержки = **450 000 руб./год.**
- **ALE' (Новый годовой убыток):** EDR блокирует большинство атак на этапе исполнения, а изолированные бэкапы позволяют восстановить данные за 2 часа без выплаты выкупа. Остаточный риск ($EF' = 0,1$, т.е. 10% ущерба от кратковременного простоя).

$$SLE' = AV \times EF' = 3\,000\,000 \times 0,1 = 300\,000 \text{ руб.}$$

$$ALE' = SLE' \times ARO = 300\,000 \times 1 = 300\,000 \text{ руб./год.}$$

- **Расчет CBA:**

$$CBA = ALE - ALE' - CV$$

$$CBA = 2\,400\,000 - 300\,000 - 450\,000 = 1\,650\,000 \text{ руб.}$$

Вывод по Этапу 3: Экономическая выгода от внедрения защиты составляет 1 650 000 руб. в год. Защита экономически полностью оправдана. (Подробные таблицы см. в Приложении А).

3.4. Этап 4. Программа повышения осведомленности (Security Awareness)

Поскольку угроза УБИ.170 часто активируется из-за ошибок людей, необходима целевая программа обучения.

1. **Целевая аудитория:** Сотрудники бухгалтерии, отдела продаж и склада (пользователи, работающие с первичной документацией, сделками и имеющие доступ к сетевым папкам 1С).

2. **Формат обучения и сроки:**

- **Вводное обучение:** В течение первого месяца работы (или в течение 5 рабочих дней после внедрения программы) — обязательный вебинар (30 минут) с разбором реальных кейсов фишинга. **Ответственный:** Специалист по ИБ. **Дата первого вебинара:** не позднее 15.09.2026.
- **Регулярное обучение:** Ежеквартально (раз в 3 месяца) — тренировочная фишинговая рассылка от имени «ИТ-отдела» или «Налоговой» с автоматическим перенаправлением ошибшихся на 5-минутный обучающий модуль.
- **Информационная поддержка:** Визуальная памятка в корпоративном мессенджере с примерами подозрительных писем, обновляемая ежемесячно.

3. **Правила ИБ (для закрытия человеческого фактора):**

- (a) Категорически запрещено открывать вложения (особенно *.docx*, *.xlsm*, *.zip*, *.exe*) и переходить по ссылкам в неожиданных или подозрительных письмах, даже если тема кажется срочной («Срочная сверка», «Изменение реквизитов»).
- (b) Если письмо кажется легитимным (например, от известного контрагента), перед открытием вложения необходимо вручную проверить полный адрес отправителя (домен после символа @).
- (c) При малейшем сомнении в подлинности письма не предпринимать никаких действий, а немедленно переслать его специалисту ИБ для проверки. Время реакции на подозрительное письмо — не более 5 минут.

- (d) Запрещается сохранять критичные финансовые документы на «Рабочий стол» или в папку «Загрузки». Все файлы должны храниться только в защищенных сетевых папках, которые автоматически попадают в политику резервного копирования.
- (e) **Регулярная проверка резервных копий:** Ежеквартально (не реже 1 раза в 3 месяца) проводить тестовое восстановление критичных баз данных 1С из изолированного бэкапа для подтверждения их целостности и работоспособности. Результаты проверок фиксировать в журнале ИБ.

4. Метрики и оценка эффективности программы (KPI):

- **KPI 1:** Не менее 95% сотрудников целевой аудитории должны пройти вводное обучение в установленные сроки.
- **KPI 2:** Доля сотрудников, кликнувших на тестовую фишинговую рассылку, не должна превышать 5% к концу первого квартала и 2% к концу года.
- **Процедура сертификации знаний:** После каждого обучающего модуля сотрудники проходят контрольное тестирование из 5 вопросов. Проходной балл — 80%. Сотрудники, не сдавшие тест, направляются на повторное обучение в течение 3 рабочих дней.

4. Заключение

В ходе выполнения домашней работы №3 был проведен комплексный анализ рисков информационной безопасности на примере критичного ИТ-актива — Сервера 1С:Предприятие.

В соответствии с заданием были выполнены следующие этапы:

1. Идентифицирована угроза неправомерного шифрования информации, которой присвоен код УБИ.170 по классификатору БДУ ФСТЭК России. Риск сформулирован строго в соответствии с требуемым шаблоном.
2. Проведен качественный анализ риска: описан технический сценарий атаки (шифрование файлов *.1cd*, *.mdf*, *.cf*), по матрице рисков инцидент оценен как «Высокий». Сформулирован бизнес-критерий неприемлемости простоя более 2 часов.
3. Выполнена количественная финансовая оценка риска. Рассчитаны показатели AV (3 млн руб.), SLE (2,4 млн руб.) и ALE (2,4 млн руб./год). Обоснован выбор ARO = 1 на основе экспертной оценки, опирающейся на аналитику Positive Technologies серии CODE RED.
4. Обоснована экономическая целесообразность внедрения контрмер (KES 11 + Veeam Backup & Replication 12 по правилу 3-2-1). Анализ затрат и выгод (CBA) показал чистую экономическую выгоду в размере 1 650 000 руб. в год. Внедрение мер снижает ожидаемый годовой убыток на 87,5%, а срок окупаемости защиты составляет менее 3 месяцев.
5. Разработана целевая программа Security Awareness для бухгалтерии, отдела продаж и склада, включающая вебинары, имитацию фишинга, 5 строгих правил поведения и систему метрик эффективности (KPI) с обязательным тестированием знаний.

Таким образом, цели и задачи работы полностью достигнуты.

5. Список использованных источников

1. Банк данных угроз безопасности информации ФСТЭК России (БДУ). УБИ.170: Угроза неправомерного шифрования информации. — URL: <https://bdu.fstec.ru/threat/ubi.170> (дата обращения: 06.09.2026).
2. ГОСТ Р ИСО/МЭК 27005-2021. Информационная технология. Методы и средства обеспечения безопасности. Менеджмент рисков информационной безопасности. — М.: Российский институт стандартизации, 2021. — 52 с.
3. ГОСТ Р ИСО/МЭК 27001-2021. Информационная технология. Системы менеджмента информационной безопасности. Требования. — М.: Российский институт стандартизации, 2021. — 32 с.
4. Positive Technologies. Аналитические отчёты серии CODE RED (2024–2025 гг.) о ландшафте киберугроз и ransomware-атаках на российские организации. — URL: <https://www.ptsecurity.com/ru-ru/research/analytics/> (дата обращения: 06.09.2026).
5. Фаулер Д. Количественная оценка киберрисков. Метод FAIR. — М.: ДМК Пресс, 2020. — 256 с.
6. Шабалин А.М. Материалы лекций и методические указания по курсу «Менеджмент и аудит ИБ». — ОАНО ДПО «ВЫШТЕХ», 2026.
7. Домашнее задание №3 (файл lab3 по желанию.pdf), предоставленное преподавателем. — 2026.

ПРИЛОЖЕНИЕ А. РАСЧЕТНЫЕ ТАБЛИЦЫ И МАТРИЦЫ

Таблица 1. Матрица оценки рисков (Качественный анализ)

Вероятность (Р) \ Последствия (I)	Низкие (I)	Средние (I)	Высокие (I)
Высокая (Р)	Средний	Высокий	Высокий
Средняя (Р)	Низкий	Средний	Высокий
Низкая (Р)	Низкий	Низкий	Средний

Примечание: В нашем сценарии Р=Высокая, I=Высокая. Итоговый риск попадает в зону **Высокий**.

Таблица 2. Количественная оценка риска и расчет СВА

Показатель	Расшифровка	Значение	Формула / Обоснование
AV	Asset Value (Стоимость актива)	3 000 000 руб.	Стоимость сервера, лицензий, данных и простоя
EF	Exposure Factor (Коэф. ущерба)	0,8 (80%)	Доля данных, шифруемая ransomware
SLE	Single Loss Expectancy (Разовый убыток)	2 400 000 руб.	$AV \times EF$ (3 000 000 × 0,8 = 2 400 000)
ARO	Annualized Rate of Occurrence (Частота)	1	Экспертная оценка на основе аналитики PT CODE RED
ALE	Annualized Loss Expectancy (Годовой убыток)	2 400 000 руб.	$SLE \times ARO$ (2 400 000 × 1 = 2 400 000)
CV	Cost of Countermeasure (Стоимость защиты)	450 000 руб.	Лицензии KES 11 + Veeam Backup 12 (год)
ALE'	Остаточный годовой убыток (после защиты)	300 000 руб.	$(AV \times EF') \times ARO$ (3 000 000 × 0,1 × 1 = 300 000)
СВА	Cost-Benefit Analysis (Эконом. выгода)	1 650 000 руб.	$ALE - ALE' - CV$ (2 400 000 – 300 000 – 450 000 = 1 650 000)